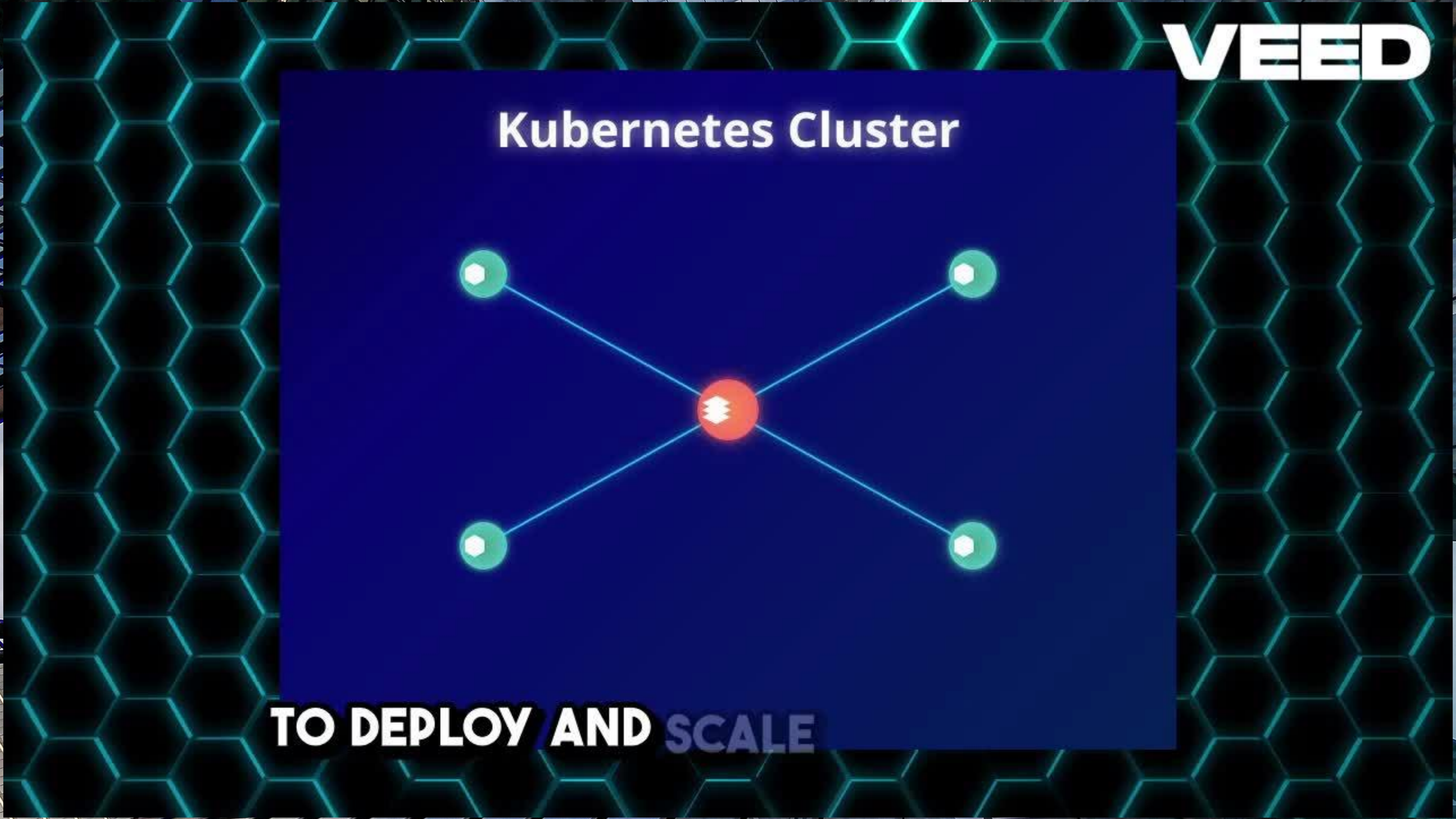
Container-Native Security & Policy Management SYSTEM

10/09/2025

CAPSLock: Container-Aware Policy Security Lock

IAS – Cyber Security

FACULTY OF COMPUTING



FACULTY OF COMPUTING

Multi-Environment Deployment System

Specialisation: Cyber Security

IT22347626

KULATUNGA K K M D

Multi-Environment Deployment System

GAP

No Kubernetes-native framework for unified policy promotion across

Shortcomings

GitOps (ArgoCD/FluxCD) → deployment only, no policy orchestration.

Solution & Objectives

Unified Security Lifecycle Orchestration (USLO): manages policy promotion from dev → staging → prod.
(Reduce policy drift incidents by ≥50%)

Risk-Based Validation: predictive checks on compliance, ICAP coverage, config drift before promotion.
(Target: 40% fewer deployment-related vulnerabilities)

Multi-Environment Deployment System

Specialized Knowledge

Domains

- DevSecOps pipelines
- GitOps
- Multi-cloud orchestration

Technologies

- ArgoCD/FluxCD (deployment engines)
- Istio for traffic mirroring between environments
- ICAP integrated validation.

Validation

- Rollback accuracy under failure conditions.
- Compliance tests across multiple environments.

Multi-Environment Deployment System

Specialized Knowledge

Data & Ethics

- Test clusters with CIS benchmark configs
- Emulated promotion pipelines (dev → staging → prod)

Validation

- Promotion latency vs. rollback times.
- Policy parity index across clusters.
- Reduction in environment drift.

Multi-Environment Deployment System

Implementation Details

Real-world Use

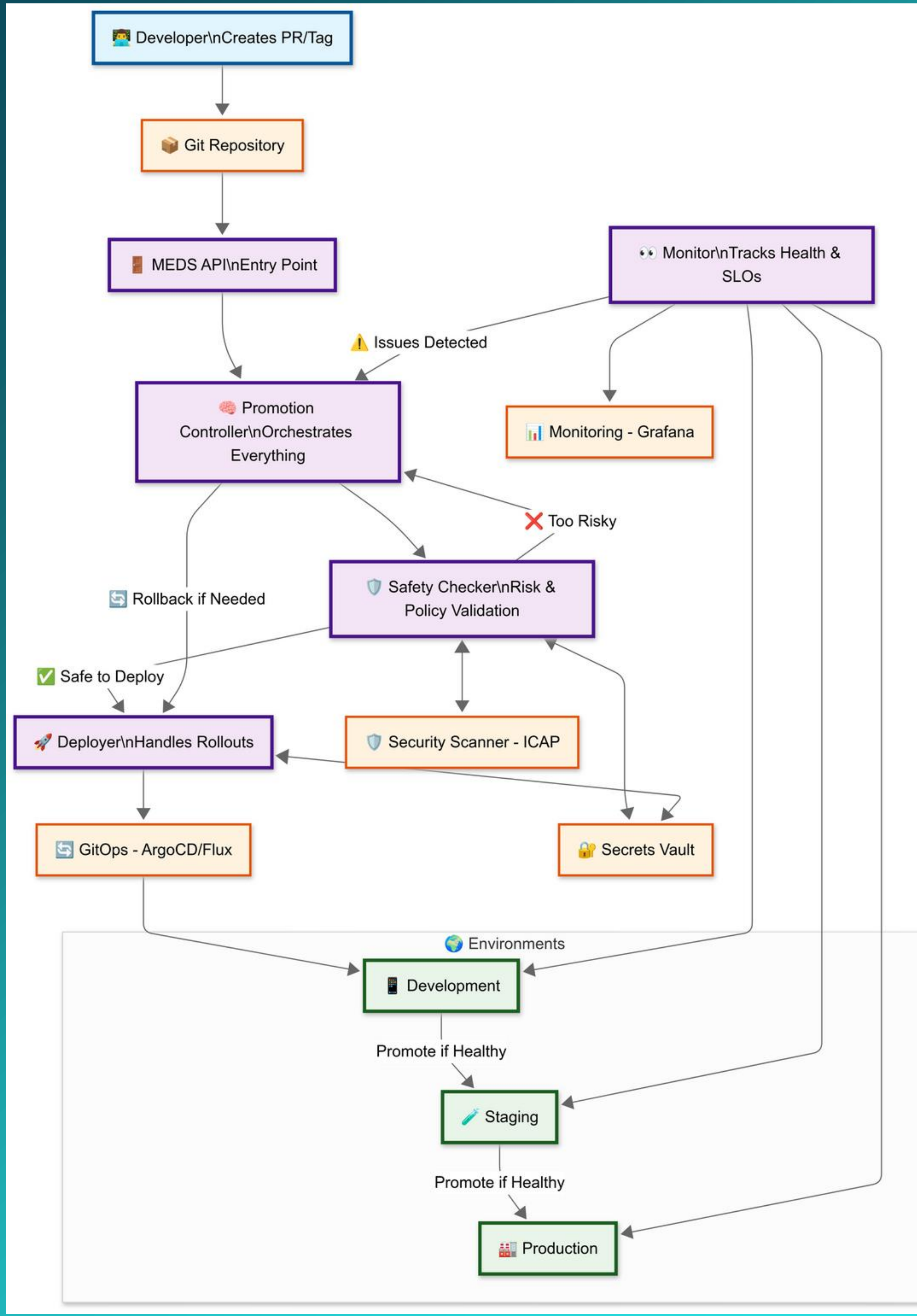
- Prevents unsafe code reaching prod.
- Auditable promotion history for compliance.
- Reduces environment drift risk

System Flow

Code commit → GitOps → ICAP validation → Risk-based gate → Policy promotion

System diagram

Multi-Environment Deployment System



Kubernetes ICAP Operator

Specialisation: Cyber Security

IT22353634

Guruge S A L

Kubernetes ICAP Operator

Problem

Kubernetes’ autoscaler only uses CPU and memory, which fails to reflect the real health of malware scanners.

Gap

No Kubernetes-native solution combines ICAP/ClamAV with health scoring and adaptive autoscaling.

Objectives

- Develop a **Dynamic Health Scoring model** for Kubernetes malware scanning that improves workload health accuracy.
- Implement **adaptive autoscaling** based on the health score to achieve better resource efficiency and responsiveness than default HPA.

Kubernetes ICAP Operator

Specialized Knowledge

Existing Solutions

- Manual ICAP/ClamAV → static, high overhead, poor scalability.
- Default HPA (CPU/mem) → ignores security metrics, causes under/over provisioning.

Data & Testing

- Datasets : EICAR files, infected container images, and synthetic exploits.
- Tests will run in a Kubernetes lab to test detection and scaling.

Technologies

- Kubernetes
- ICAP + ClamAV
- Prometheus & Grafana
- HPA / KEDA
- Kubebuilder

Kubernetes ICAP Operator

Implementation Details

Real-world Use

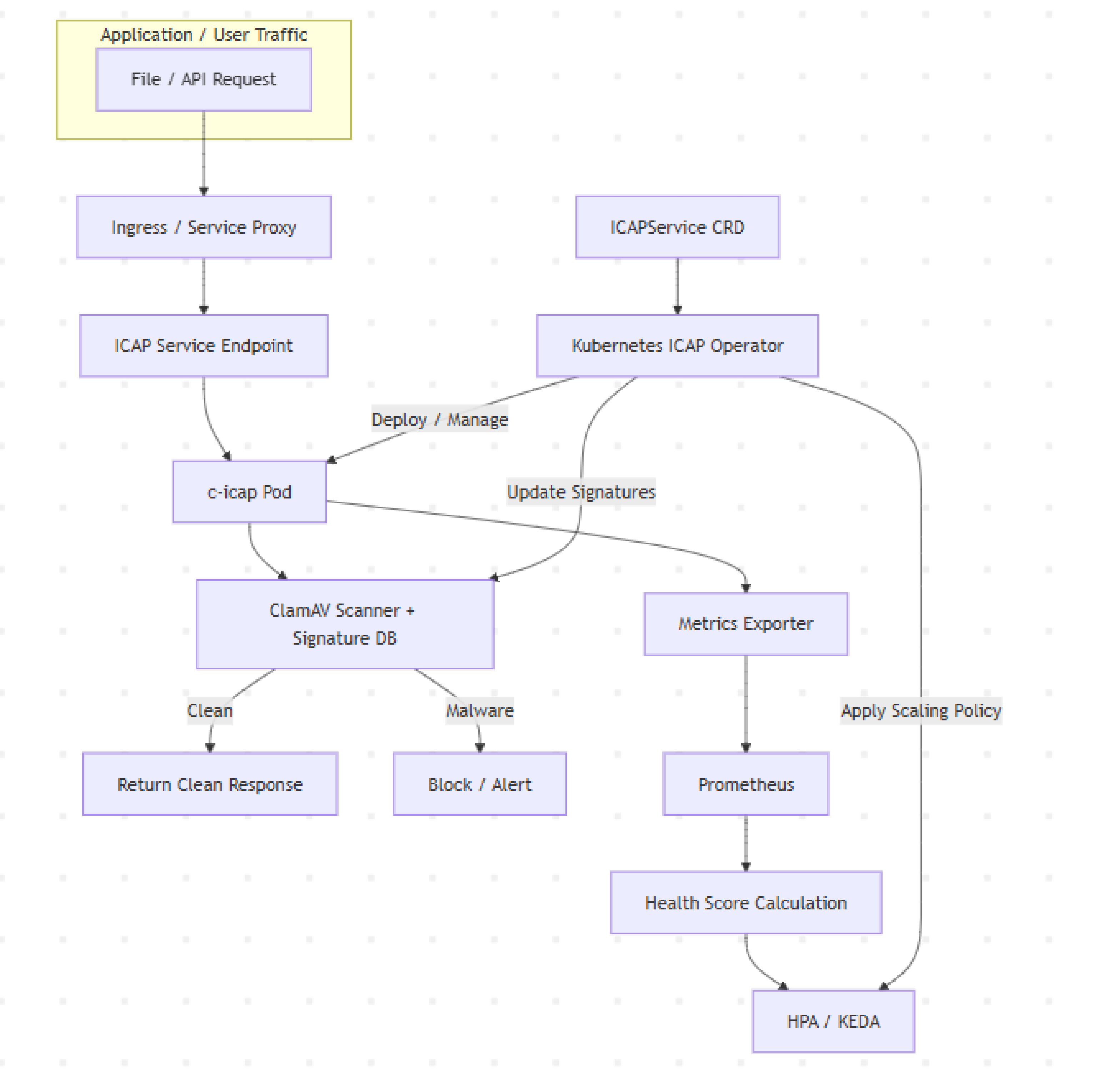
- Efficient malware scanning in production.
- Automatic scaling under attack traffic spikes.
- Resource savings under low-load conditions.

System Flow

Traffic scanning → monitors health → triggers scaling

Kubernetes ICAP Operator

System Diagram



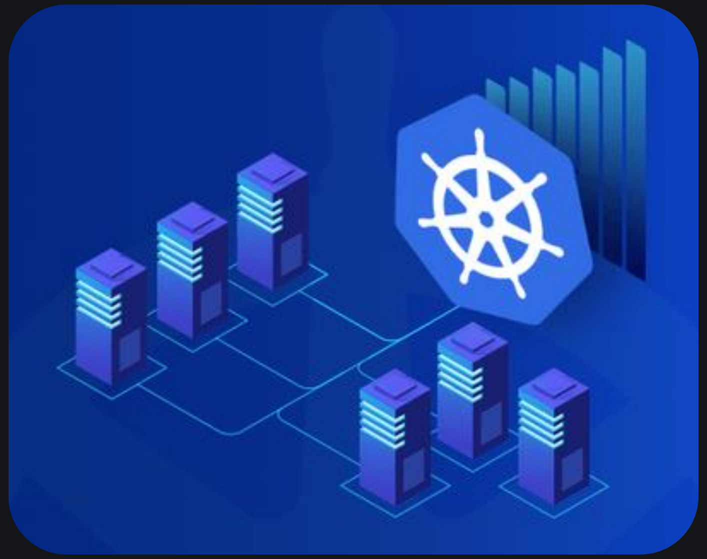
Environment-Aware Policy Engine

Specialisation: Cyber Security

IT22338716

RAIGAMBANDARAGE N K

Environment-Aware Policy Engine



GAP

No automated adaptation of security benchmarks (e.g., CIS Kubernetes Benchmark) across multi-environment deployments

Shortcomings

Existing policy engines (OPA/Kyverno) lack environmental awareness and only support static CIS rules → results in drift and misalignment.

Solution and Objectives

Objective: To automatically detect deployment environments and dynamically synthesize context-appropriate security policies for Kubernetes clusters while maintaining consistency across development, staging, and production environments.

Solutions:

- CIS-Centric Policy Synthesis to generate environment-specific policies with CIS controls as the baseline, with expandability to other security frameworks.
- Real-time Conflict Resolution ensuring no contradictory rules across multi-environment deployments.

Environment-Aware Policy Engine

Specialized Knowledge

Domains

- Policy-as-Code
- Security Benchmark Automation
- Kubernetes Admission Controls.

Technologies

- OPA/Kyverno with CIS policies
- Context classifiers (labels, namespaces, metadata)
- Conflict detection powered by semantic validation.

Validation

- **Primary measure:** % of CIS controls consistently enforced across dev/stage/prod.
- Cross-benchmark consistency checks when CIS is combined with NIST/PCI DSS.

Environment-Aware Policy Engine

Specialized Knowledge

Data & Ethics

- Benchmark datasets: CIS Kubernetes Benchmark v1.24+, NVD datasets for mapping.
- Future-proofing: compliance packs for NIST 800-190 and PCI DSS can be slotted in modularly.

Validation

- Policy coverage (% CIS rules enforced).
- Conflict resolution accuracy.
- Performance overhead of multi-policy enforcement.

Environment-Aware Policy Engine

Implementation Details

Real-world Use

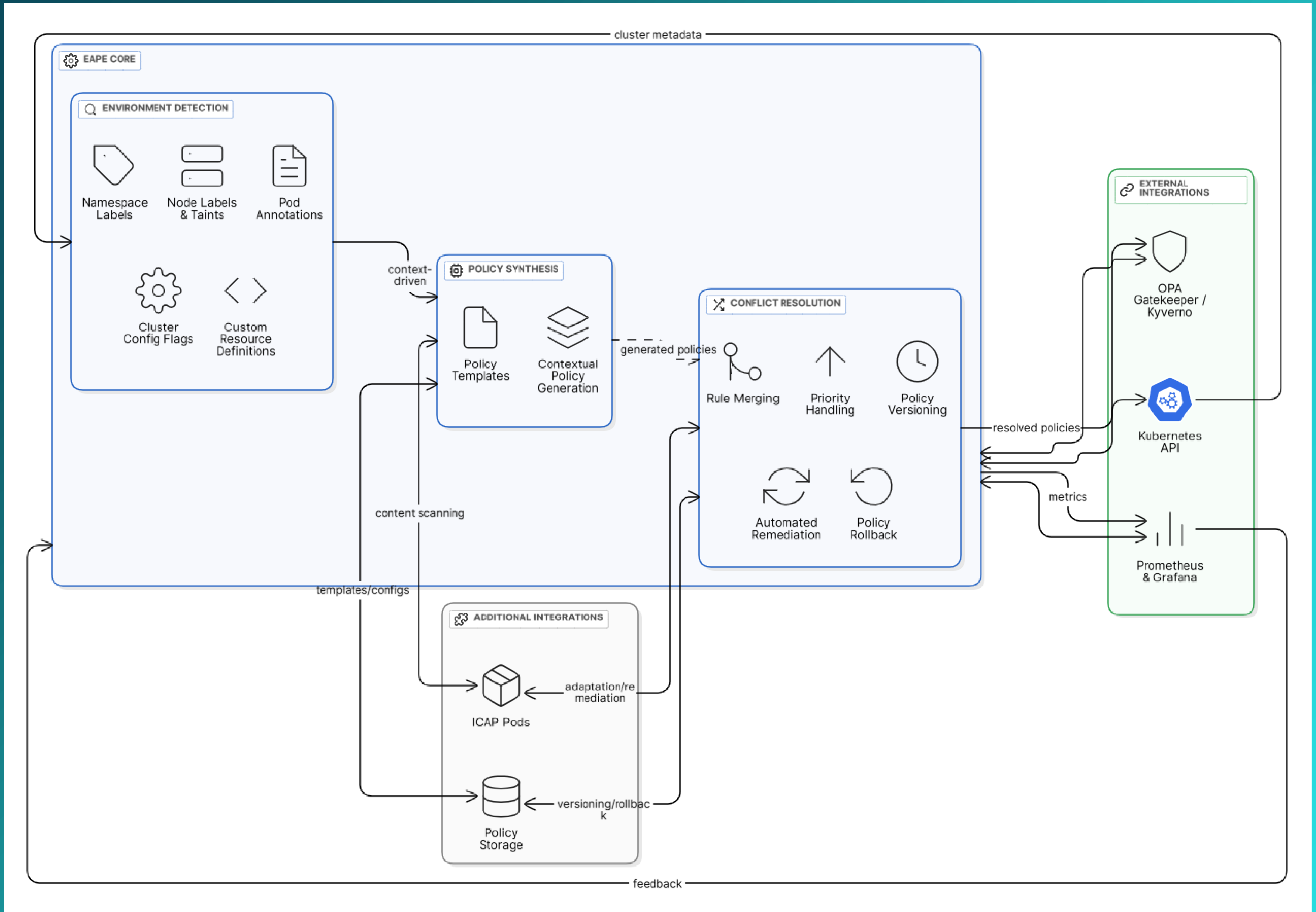
- Ensures CIS compliance from dev to production.
- Provides flexibility to integrate sector-specific standards (finance, healthcare).
- Automates what is usually manual compliance audits.

System Flow

Detect environment → Apply CIS baseline policies → Adapt to context → Extend to optional frameworks (NIST/PCI DSS)

Environment Aware Policy Engine

System Diagram



Smart Service Discovery & Load Balancing

Specialisation: Cyber Security

IT22345028

PANDUKABHAYA H D T

Smart Service Discovery & Load Balancing

GAP

No Kubernetes-native framework for unified policy promotion across

Shortcomings

GitOps (ArgoCD/FluxCD) → deployment only, no policy orchestration.

Solution

- **Predictive Telemetry Routing (PTR):** Leverages real-time latency, queue depth, and health metrics to proactively reroute ICAP traffic before degradation. *(Target: ~40–50% reduction in p95/p99 latency compared to Istio defaults)*
- **Compliance-Aware Traffic Management:** Embeds PCI DSS and CIS rules into routing logic, generating audit-ready logs for every decision. *(Target: 100% compliance log coverage and <5s failover recovery time)*

Smart Service Discovery & Load Balancing

Specialized Knowledge

Domains

- DevSecOps pipelines
- GitOps
- Multi-cloud orchestration

Technologies

- ArgoCD/FluxCD (deployment engines)
- Istio for traffic mirroring between environments
- ICAP integrated validation.

Validation

- Rollback accuracy under failure conditions.
- Compliance tests across multiple environments.

Smart Service Discovery & Load Balancing

Specialized Knowledge

Data & Ethics

- Test clusters with CIS benchmark configs
- Emulated promotion pipelines (dev → staging → prod)

Validation

- Promotion latency vs. rollback times.
- Policy parity index across clusters.
- Reduction in environment drift.

Smart Service Discovery & Load Balancing

Implementation Details

Real-world Use

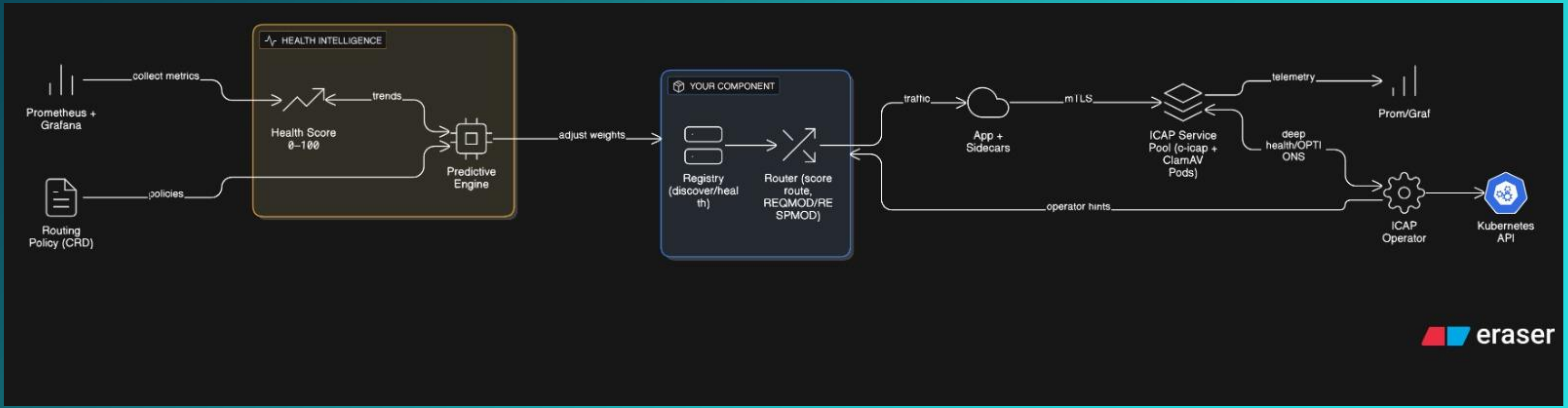
- Prevents unsafe code reaching prod.
- Auditable promotion history for compliance.
- Reduces environment drift risk

System Flow

Code commit → GitOps → ICAP validation → Risk-based gate → Policy promotion

Smart Service Discovery & Load Balancing

System Diagram



CAPSLOCK: CONTAINER-AWARE POLICY SECURITY LOCK

Commercialisation Plan

TARGET MARKET

- Enterprises with Kubernetes workloads under strict compliance (finance, gov, healthcare)

VALUE PROPOSITION

- CAPSLock = first Kubernetes-native ICAP security orchestration platform
- Reduces DevOps overhead, ensures compliance, automates scaling

COST AND ROI

- Minimal infra (open-source base)
- Commercial support/licensing model → monetisation

INTELLECTUAL PROPERTY

- Open-source core for adoption
- Proprietary enterprise features → differentiation

THANK YOU